

CSCI400-Capstone Course

Professor Meryem Abouali

Cybersecurity Project Implementation Submission - Project Proposed Solution -Part 2

**Title: Password Security Analysis and Brute-Force Attack Simulation on
GroceryGo Web Application**

Sangram Mathews, Ayman Fahim, Maciej Leniartek

1. Objective

The objective of this project is to evaluate the security of password storage mechanisms in the GroceryGo web application while also simulating and defending against brute-force attacks. There are both Offline and Online portions of this project. The project aims to analyze how different hashing techniques (SHA-256, salted hashing, and bcrypt) affect password strength and resistance to cracking attacks.

Additionally, a brute-force attack simulation is implemented to test how vulnerable the system is to real-world attacks when there are weak passwords.

The expected outcome is to demonstrate how weak hashing methods are vulnerable to attacks, how brute-force attacks operate, and how detection and prevention mechanisms can mitigate these threats.

2. Introduction

2.1 Overview of the Experiment

This project focuses on **web application authentication security**, specifically password storage and login protection.

Passwords are a primary target for attackers. If a database is compromised, attackers can perform **offline attacks** such as:

- Brute-force attacks
- Dictionary attacks

The experiment evaluates:

- SHA-256 (no salt) → insecure
- Salted SHA-256 → moderate security
- bcrypt → secure adaptive hashing

The project also integrates **online attack simulation (brute-force login attempts)** to demonstrate real-world attack scenarios.

Tools used:

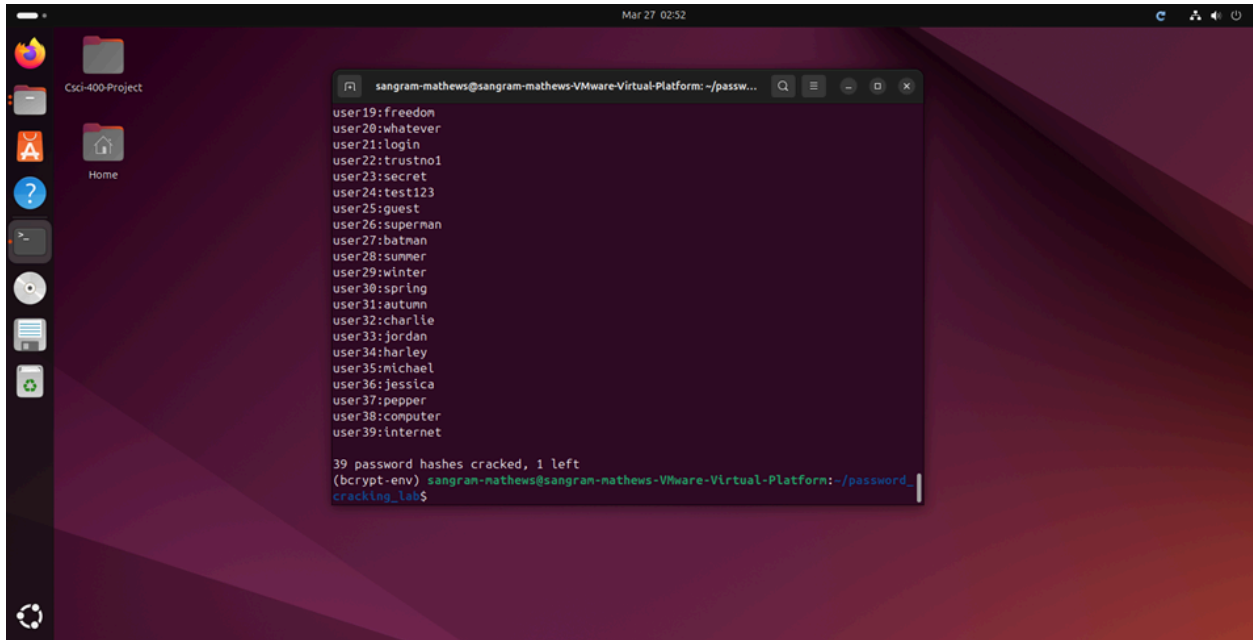
- GroceryGo (React + Firebase)
- SQLite database
- Python (hashing simulation)
- BurpSuite
- Hashcat / John the Ripper
- Linux VM

2.2 Problem Identification (Nature of Attack)

Two major attack types are addressed:

1. Offline Password Cracking

- Attacker gains database access
- Extracts hashed passwords
- Uses tools like Hashcat / John the Ripper
- Performs brute-force attacks
- Recovers weak passwords



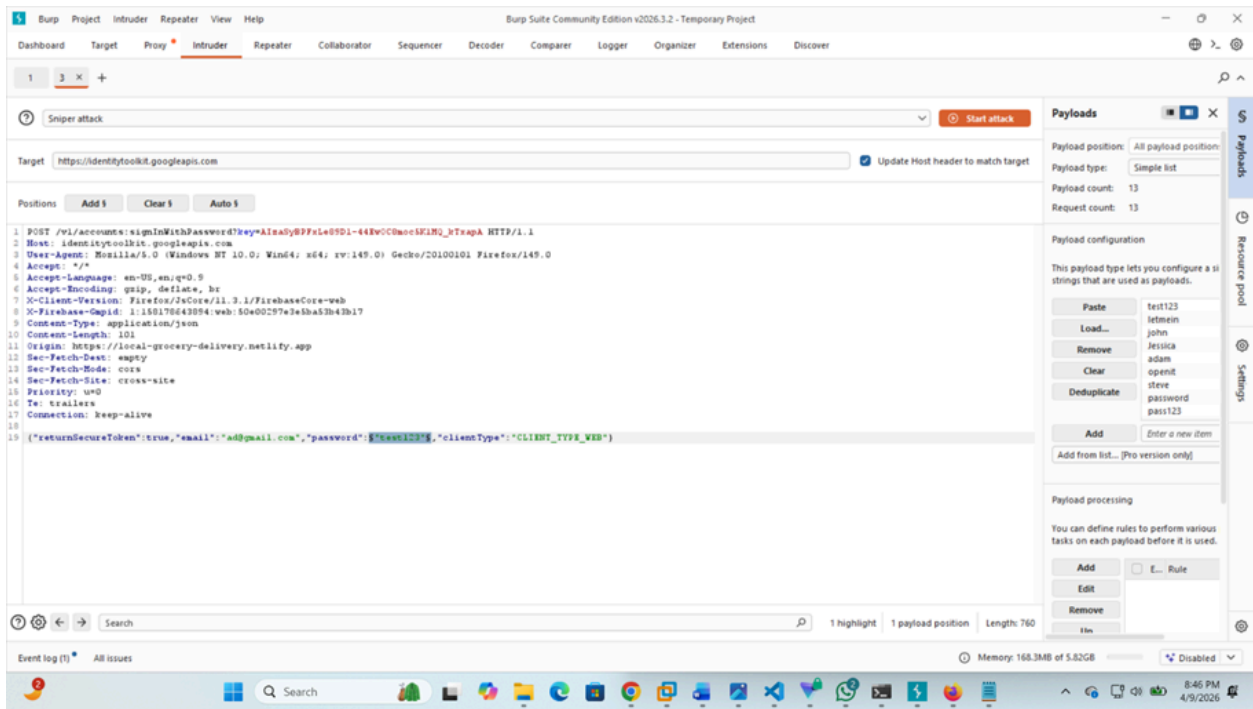
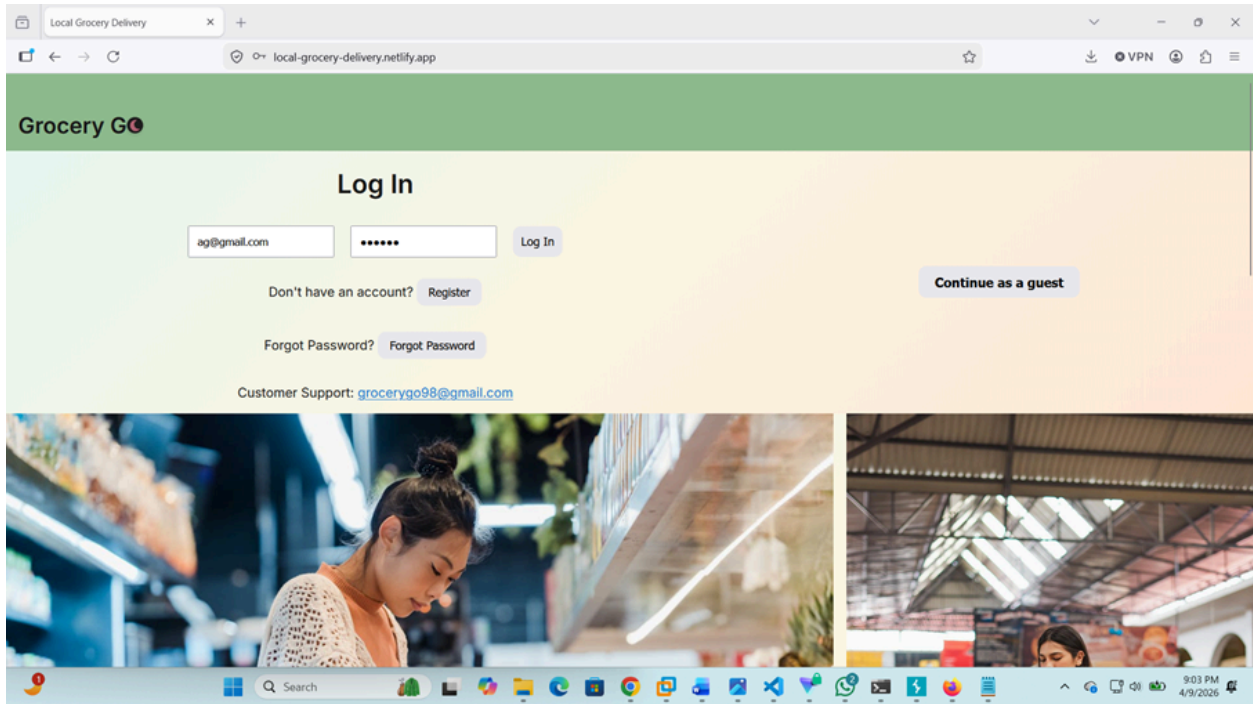
2. Online Brute-Force Attack

Attackers:

- Repeatedly attempt login Using BurpSuite
- Try different password combinations
- Exploit lack of rate limiting

These attacks succeed when:

- Weak passwords are used
- No salting is applied
- Weak hashing algorithms are applied
- No login protections exist



3. Protocols and Algorithms for Prevention, Detection, and Countermeasures

3.1 Prevention Mechanisms

Protocols

The following security protocols were implemented:

- Secure password hashing (bcrypt)
- HTTPS secure communication
- Account lockout policy
- Multi-Factor Authentication

Algorithms

The following prevention algorithms were implemented:

1. Rate Limiting Algorithm

Limits login attempts:

- 5 failed attempts allowed
- Account temporarily locked after threshold

2. Password Complexity Algorithm

Password requirements:

- Minimum 8 characters
- Uppercase letters
- Numbers
- Special characters

3. Hashing algorithm and Salting

Salting and bcrypt slows password cracking by using adaptive hashing.

Implementation Details

- bcrypt implemented in authentication system
- Rate limiting applied to login API
- Password validation added to registration page

3.2 Detection Mechanisms

Monitoring Tools

- Login activity logs
- Firebase authentication logs

- Custom logging system

Detection Algorithms

- Track failed login attempts per user
- Threshold-based detection (e.g., 5 failed attempts)
- IP-based anomaly detection

Implementation Process

- Store login attempts in database
- Monitor:
 - Frequency of attempts
 - IP address behavior
 - Threshold reached within time limit
- Flag suspicious activity

Example detection logic:

IF failed_attempts > 5 within 1 minute:
Flag as brute-force attack

3.3 Countermeasures

Immediate Actions

When brute force detected:

- Account temporarily locked
- IP blocked
- Alert generated

Long-Term Solutions

- Implement bcrypt hashing
- Add CAPTCHA after failed attempts
- Enable Multi-Factor Authentication
- Improve password policies

Implementation Strategy

Countermeasures integrated into:

- Login authentication system
- Database security
- Monitoring system

